AWS Certified DevOps Engineer – Professional（DOP-C02）　タスク 6.2　#21

データ保護とネットワークのセキュリティ

セキュリティグループ・ネットワーク ACL・Network Firewall・VPC エンドポイントポリシー・WAF（マネージドルール・レートベース）・Shield・Firewall Manager・aws:SecureTransport、ACM・DNS 検証・ワイルドカード・Private CA、KMS（キーポリシー・クロスアカウント・エンベロープ暗号化・ローテーション・マルチリージョンキー・グラント）・CloudHSM・S3 の暗号化とバケットキー・パブリックアクセスブロック・EBS／RDS の暗号化・Macie

各ページの下に、根拠にした資料（AWS の DOP-C02 試験ガイド、VPC・WAF／Shield／Firewall Manager・PrivateLink・ACM・Private CA・KMS・CloudHSM・S3・EBS・RDS・Macie の各ガイド、Network Firewall〔英語版〕）を書いた。『』の中はドキュメントの原文どおり

第1章

ネットワークを守る

層ごとに道具が違う。多層で守る。

VPC の中の守り

	セキュリティグループ	ネットワーク ACL
付ける先	ENI（インスタンス）	サブネット
状態	ステートフル	ステートレス（戻りも許可）
ルール	許可だけ	許可と拒否
評価	すべてのルール	番号の小さい順、最初に一致

Network Firewall
ステートフル検査・IPS（Suricata）・ドメインで外への通信を絞る。専用サブネット＋ルートテーブル

VPC エンドポイントポリシー
エンドポイント経由で使えるものを絞る。IAM・バケットポリシーは置き換えない（aws:SourceVpce）

特定の IP を拒否 → NACL。戻りが通らない → NACL のエフェメラルポート。

出典：セキュリティグループのルール『拒否ルールは指定できません。』／ネットワーク ACL の基本／Network Firewall（英語版）／エンドポイントポリシー

Web と DDoS と組織全体

道具	守るもの	ポイント
AWS WAF	CloudFront・ALB・API Gateway への HTTP(S)	マネージドルール（SQLi・XSS）、レートベースのルール
Shield Standard	ネットワーク層の一般的な DDoS	追加料金なし・自動
Shield Advanced	大規模な DDoS	検出・緩和の強化、対応チーム、料金の保護
Firewall Manager	組織の全アカウント	WAF・SG・Network Firewall・Shield Advanced を新しいものにも自動で
aws:SecureTransport	S3 などへの通信	false を拒否して HTTPS だけに

出典：AWS マネージドルール／レートベースのルール『レートベースのルールでは、受信リクエストをカウントし、レートが速すぎる場合にはリクエストを制限します。』／AWS Shield／Firewall Manager／S3 のセキュリティのベストプラクティス

第2章

証明書

公開は ACM、社内は Private CA。

ACM と Private CA

ACM のパブリック証明書
無料。ELB・CloudFront・API Gateway に付ける

↓ 検証

DNS 検証（CNAME を残す）→ 自動更新
メール検証は期限前にメール。インポートした証明書は自動更新されない

> CloudFront 用は us-east-1 で取る。ELB 用は同じリージョン。

場面	使うもの
サブドメインが多い	*.example.com（数の制限なし）
社内の mTLS	AWS Private CA（ルート CA・下位 CA）
Roles Anywhere	Private CA をトラストアンカーに

出典：ACM と統合されたサービス『CloudFront で ACM 証明書を使用するには、米国東部 (バージニア北部) リージョンの証明書をリクエスト (またはインポート) している必要があります。』／DNS 検証／マネージド証明書の更新／Private CA

第3章

暗号化とキーとデータの管理

だれがキーを使えるか、どこにキーがあるか。

KMS と CloudHSM

GenerateDataKey
平文のデータキー＋暗号化されたデータキー

↓ 平文のデータキーで手元で暗号化（Encrypt API は 4 KB まで）

暗号文＋暗号化されたデータキーを一緒に保存
エンベロープ暗号化

機能	ポイント
キーポリシー	キーごとに 1 つ。主なアクセス制御
クロスアカウント	キーポリシー＋相手の IAM ポリシー
グラント	ポリシーを変えずに一時的に許可
自動ローテーション	既定で毎年。ID は同じ。急ぎはオンデマンド
マルチリージョンキー	別リージョンでそのまま復号
CloudHSM	シングルテナント・FIPS 140 レベル 3

出典：キーポリシー／他のアカウントのユーザーに KMS キーの使用を許可する『別のアカウントのユーザーとロールに KMS キーを使用するアクセス許可を付与するには、2 つの異なるタイプのポリシーを使用する必要があります。』／暗号化の必須事項／ローテーション／マルチリージョンキー／グラント／CloudHSM

保存するデータを守る・見つける

対象	ポイント
S3 の暗号化	既定で SSE-S3。KMS で管理・記録したいなら SSE-KMS（＋バケットキーで費用を最大 99% 減）
S3 の公開	パブリックアクセスブロック（組織・アカウント・バケット・アクセスポイント）
EBS	デフォルトの暗号化はリージョンごと。既存のボリュームは変わらない
RDS	後から直接は暗号化できない → スナップショットを暗号化してコピー → 復元
機密データ	Macie の自動検出（サンプリングで継続）→ EventBridge・Security Hub

出典：S3 の暗号化／バケットキー／パブリックアクセスのブロック／EBS のデフォルトの暗号化／RDS の暗号化『ただし、暗号化されていないスナップショットのコピーは暗号化できるので、暗号化されていない DB インスタンスに効果的に暗号化を追加できます。』／Macie

本番での問われ方

ねらい	見るところ
ネットワーク	SG と NACL（ステートフル・拒否・順番）、Network Firewall、エンドポイントポリシー
Web・DDoS	WAF のマネージドルールとレートベース、Shield Standard と Advanced、Firewall Manager
証明書	CloudFront は us-east-1、DNS 検証で自動更新、ワイルドカード、Private CA
KMS	キーポリシー、クロスアカウントは両方、エンベロープ暗号化、ローテーション、マルチリージョン、グラント、CloudHSM
データ	SSE-S3 が既定、バケットキー、aws:SecureTransport、パブリックアクセスブロック、EBS はリージョンごと、RDS はスナップショット経由、Macie

出典：AWS Certified DevOps Engineer - Professional (DOP-C02) 試験ガイド タスク 6.2